

Document Disclaimer

This is a home lab Privacy Impact Assessment (PIA) document created for learning purposes.

“NorthBridge Health Analytics” is a fictional company.

Privacy Impact Assessment (PIA)

NorthBridge Health Analytics

Patient Appointment Scheduling & Telehealth Intake Process

Prepared By: Kingsley

Date: May 27, 2026

Region: Canada

1. Project Overview

NorthBridge Health Analytics is a Vancouver-based healthcare technology company that provides digital scheduling and telehealth services to medical clinics across Canada.

This Privacy Impact Assessment (PIA) evaluates the Patient Appointment Scheduling and Telehealth Intake process, where patient personal information and health-related data are collected, processed, stored, and shared for healthcare service delivery purposes.

The purpose of this assessment is to identify privacy risks and evaluate security and privacy controls implemented to protect sensitive information in accordance with Canadian privacy regulations, including PIPEDA and healthcare privacy best practices.

2. Personal Information Collected

NorthBridge Health Analytics collects the following patient information during appointment scheduling and telehealth intake processes:

- Full name
- Home address
- Phone number
- Email address
- Date of birth
- Provincial health card number
- Emergency contact information
- Medical symptoms and health history
- Prescription information
- Payment and billing information
- IP address and device metadata

Certain information collected during this process is classified as highly sensitive due to the inclusion of healthcare and financial information.

3. Purpose of Collection

The information is collected to support healthcare operations and deliver telehealth services.

- Schedule patient appointments

- Verify patient identity
- Facilitate virtual healthcare consultations
- Maintain medical and appointment records
- Process billing and insurance transactions
- Meet healthcare regulatory obligations
- Support cybersecurity monitoring and fraud prevention

Under PIPEDA, the organization collects only information necessary for legitimate healthcare and operational purposes and obtains patient consent prior to data collection.

4. Data Storage

Patient information is securely stored within Canadian-hosted infrastructure environments.

- Encrypted cloud storage platforms
- Secure telehealth application databases
- Internal healthcare management systems
- Encrypted backup repositories
- Security monitoring and audit logging systems

Data residency requirements are maintained to support Canadian privacy compliance expectations and reduce cross-border privacy risks.

5. Access to Information

Access to patient information is restricted to authorized personnel and approved third-party service providers.

- Healthcare providers
- Scheduling coordinators
- Billing and finance personnel
- IT security administrators
- Privacy and compliance personnel
- Approved telehealth vendors

Role-Based Access Control (RBAC) principles are implemented to ensure users can only access information required for their job responsibilities.

6. Identified Privacy Risks

- Unauthorized access to patient records
- Exposure of healthcare and billing information
- Phishing and credential theft attacks

- Insider threats and misuse of privileged access
- Misconfigured cloud storage environments
- Third-party vendor security weaknesses
- Accidental disclosure of sensitive information
- Data breaches involving medical records

Due to the sensitivity of healthcare information, privacy incidents could result in regulatory penalties, reputational damage, and loss of patient trust.

7. Existing Security Controls

- Multi-Factor Authentication (MFA)
- Encryption of data at rest and in transit
- Role-Based Access Control (RBAC)
- Security awareness and privacy training
- Endpoint Detection and Response (EDR) tools
- Security Information and Event Management (SIEM) monitoring
- Regular access reviews and audits
- Data retention and secure disposal policies
- Vendor risk assessments
- Incident response and breach notification procedures

Administrative, technical, and physical safeguards are implemented to reduce privacy and cybersecurity risks associated with healthcare information processing.

8. Conclusion

This Privacy Impact Assessment identified several privacy and cybersecurity risks associated with the Patient Appointment Scheduling and Telehealth Intake process at NorthBridge Health Analytics.

The organization has implemented reasonable administrative, technical, and physical safeguards to protect sensitive patient information and support compliance with Canadian privacy requirements under PIPEDA.

Continuous monitoring, periodic privacy reviews, and ongoing security improvements are recommended to maintain strong privacy and cybersecurity practices.

9. References

- Office of the Privacy Commissioner of Canada (OPC) – Privacy Impact Assessment Guidance
- Personal Information Protection and Electronic Documents Act (PIPEDA)

- Canadian Centre for Cyber Security Best Practices

<https://www.priv.gc.ca/en/privacy-topics/privacy-impact-assessments>